OST
Ostschweizer
Fachhochschule



Entwicklung einer Phishing-Landing-Page mit Fokus auf die Umgehung automatisierter Sicherheits-scanner

23.10.2026

Autor:
András Tarlós

Betreuer:
Dr. Arno Wagner

Praxispartner:
avantguard cyber security AG

Ansprechssperson:
Sandro Ackermann

Studienarbeit - Herbst 2026

Abstract

Diese Arbeit **B** Background information

P Purpose of study

M Method used

R Results

C Conclusions and discussion

Schlüsselwörter: Cybersicherheit, Phishing-Landing-Page, Phishing, Operational Security,

Danksagung

Abkürzungsverzeichnis

Abkürzung	Bedeutung
ML	Machine Learning
DL	Deep Learning
CNN	Convolutional Neural Network
OPSEC	Operational Security

Tabelle 1: Liste aller Abkürzungen

Inhaltsverzeichnis

1 Einleitung 1
1.1 Hintergrund 1
1.2 Ziele 2
1.3 Rahmenbedingungen 2
2 Stand der Technik 3
3 Anforderungen 4
3.1 Funktionale Anforderungen 4
3.2 Nichtfunktionale Anforderungen 4
4 Design 5
4.1 Infrastruktur 5
4.2 Phishing-Landing-Page 5
4.2.1 Kategorien von Operational Security Massnahmen 5
4.3 Bot-Abwehr Strategien 6
4.4 Analyseerschwerung 8
5 Implementation 9
5.1 Übersicht 9
5.2 Beispiel 9
6 Validierung 10
6.1 Guidelines 10
6.2 Experimente 10
6.3 Testing 10
7 Schlussfolgerung & Ausblick 11
7.1 Schlussfolgerung 11
7.2 Ausblick 11
A Projektmanagement 12
A.1 Langfristiger Zeitplan 12
A.2 Vorgehen im Projekt 13
A.3 Qualitätssicherung 13
A.4 Risikomanagement 14
A.4.1 Pre-Mitigation Risiken 14
A.4.2 Post-Mitigation Risiken 15
A.5 Zeiterfassung 16
A.6 Meetings 17
A.6.1 Überblick 17
A.6.2 Protokoll 18
B Persönliche Reflexion 21

C Diagramme 22
D Tabellen 23
E Listen 24
F Literaturverzeichnis 25
G Maldev Academy 26

1 Einleitung

1.1 Hintergrund

Um Phishing zu bekämpfen, wurden viele Strategien entwickelt; einerseits existieren technische Sicherheitslösungen, die dabei helfen können, Nutzer vor Phishing-Versuchen zu bewahren, indem sie bösartige oder verdächtige Webseiten blockieren. Solche technischen Sicherheitsmassnahmen sind effektiv. Doch genau wie bei Maschinen, muss auch das Fachpersonal eines Unternehmens gehärtet werden, indem es trainiert wird, Phishing-Webseiten zu erkennen. Die Arbeit von Ho et al. [1] diskutiert, wie *Security Awareness Trainings* an sich gemäss empirischen Untersuchungen die Phishing-Awareness nicht zwangsläufig verbessern. Was bei diesem Problem hilft, ist ein praktisches, simulationsbasiertes *Security Awareness Training*, eine Phishing-Simulation. Wie die zentralen Ergebnisse von Alluqmani et al. [2] zeigen, verringert eine Phishing-Simulation die Anfälligkeit von Nutzern für Phishing-Webseiten signifikant.

avantguard cyber security AG, der Praxispartner dieser Arbeit, bietet Phishing-Simulationen für ihre Kunden an. In letzter Zeit erkennen Sicherheitssysteme jedoch die Phishing-Landing-Pages des Praxispartners, was zur gekürzten Verfügbarkeit der Simulationsumgebung führt und deren Effektivität senkt.

Eine Phishing-Simulation läuft im Allgemeinen wie in Abbildung 1 dargestellt ab:

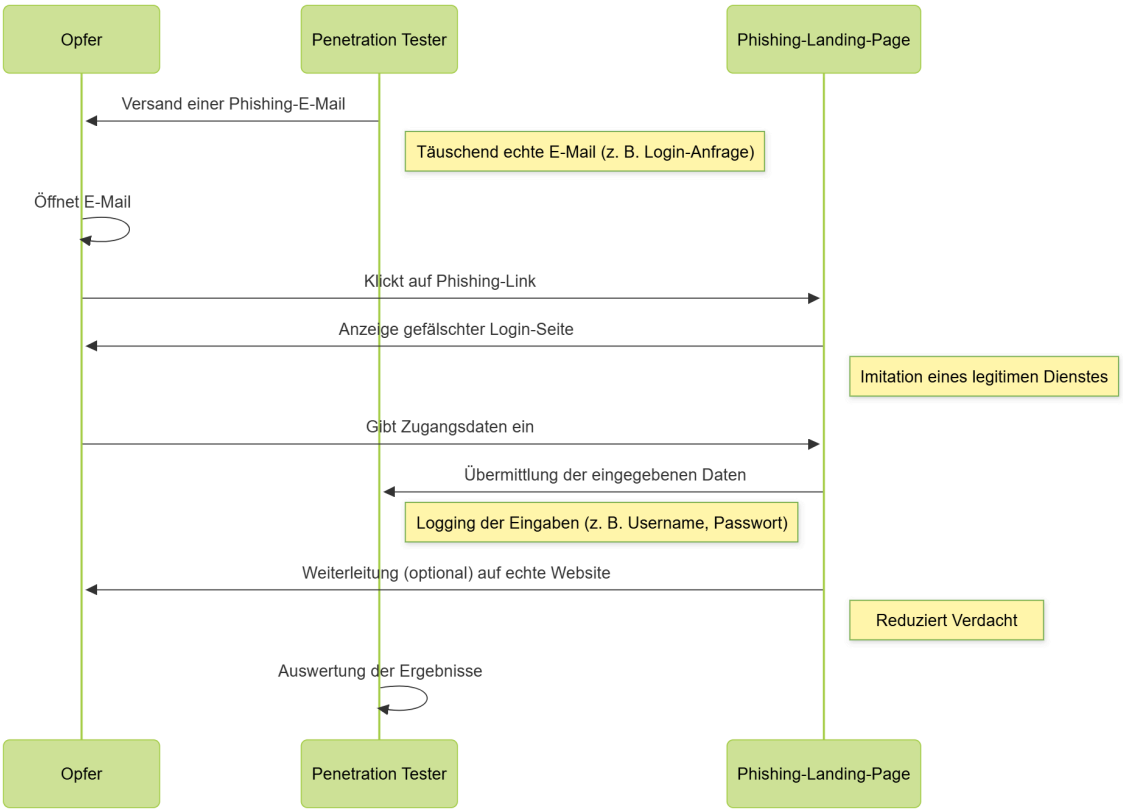


Abbildung 1: Ablauf einer Phishing-Simulation

1.2 Ziele

Ziel dieser Arbeit ist, eine Phishing-Landing-Page für avantguard cyber security AG zu entwickeln, welche gängige Sicherheitssysteme umgeht. Dadurch soll die Verfügbarkeit der Simulationsumgebung verlängert werden, damit das Personal der Kunden reibungslos von den positiven Lerneffekten der Phishing-Simulationen profitieren kann.

1.3 Rahmenbedingungen

Dies ist eine Studienarbeit in Informatik, die an der Ostschweizer Fachhochschule verfasst wird. Für die Arbeit sind 240 Stunden vorgesehen (~17 Stunden pro Woche während des Semesters). Nach einem erfolgreichen Abschluss werden dem Studierenden 8 ECTS-Credits in der Kategorie „Studien- und Bachelorarbeit“ angerechnet.

2 Stand der Technik

In diesem Abschnitt werden die aktuellen Entwicklungen und der Stand der Forschungen bezüglich Phishing-Landing-Pages und Phishing im Allgemeinen diskutiert und zusammengefasst. Die vorliegende Arbeit von Li et al. [3] bildet die Grundlage für die Diskussion.

Bei der Erkennung von Phishing-Landing-Pages ist besonders in den letzten Jahren ein signifikanter Fortschritt zu verzeichnen. Phishing-Angriffe stellen nach wie vor eine erhebliche Bedrohung für die Cybersicherheit dar, wobei Landing-Pages als ein wichtiges Mittel für den Erfolg von Phishing-Versuchen dienen.

Die signifikanten Fortschritte in den Bereichen *Machine Learning* (ML) und *Deep Learning* (DL) haben zu einer substanziellen Veränderung des Wettbewerbsumfelds von *state-of-the-art* Phishing-Detektionsmechanismen geführt. Anstelle der traditionellen Detektionsmechanismen, wie etwa regelbasierter Systeme, werden gegenwärtig zunehmend optimierte Lösungen benötigt, die imstande sind, den feinen Unterschied zwischen legitimen und bösartigen Webseiten zu erkennen. Verbesserte Techniken beinhalten text-, bild- sowie ML- und DL-basierte Algorithmen, die vermehrt in der Lage sind, typische Phishing-Muster zu erkennen [4]. *Convolutional Neural Networks* (CNN), eine Subkategorie von DL, ist zum Beispiel besonders effektiv in der Erkennung von visuellen Elementen auf Webseiten, wie gefälschte Logos oder eingebettete Texte in Screenshots [3, S. 8].

Diese Entwicklungen stellen Penetration-Tester vor Herausforderungen, insbesondere bei der Erstellung von Phishing-Simulationen; die Strategien und Umgehungstechniken müssen kontinuierlich an die neusten Trends angepasst werden, um die Effektivität einer Phishing-Simulation zu gewährleisten.

Bei dieser Arbeit handelt es sich um eine angewandte Forschungsarbeit mit Prototyping, die den Fokus klar auf 1) die umfassende und übersichtliche Erstellung einer Liste von Methoden und Strategien legt, die die Erkennung von Phishing-Landing-Pages mit modernen Technologien möglichst schwierig macht; und 2) der Entwicklung einer Phishing-Landing-Page, die *state-of-the-art* Sicherheitslösungen täuschen kann.

3 Anforderungen

MoSCow

- Es sollten 10 verschiedene statische Webseiten bei virusTotal getestet werden.
- Die finale Landing-Page muss einem Microsoft Page gleicht aussehen. 10 Personen fragen, ob ihnen etwas Verdächtiges bei der Microsoft Phishing-Landing-Page auffällt.
- Die Landing-Page muss über GoPhish laufen
- Die finale Landing-Page darf von VirustTotal nicht erkannt werden.
- Eine Phishing-Simulation sollte 7 Tage lang beibehalten werden.
- Experiment: Phishing-Webseite erstellen und verschiedenen automatisierte Scanner geben, die im Internet sind + drei verschiedenen E-Mai Clients den Link zur Phishing-Page schicken (sie scannen die URLs wahrscheinlich auch)
- Eine ausführliche Tabelle mit OPSEC Techniken sollte erstellt werden, um avantguard eine Übersicht zu geben, welche Techniken es existieren.

3.1 Funktionale Anforderungen

ID	NFR-1
Thema	
Anforderung	
Geltungsbereich	Phising-Landing-Page
Massnahmen	
Priorität	Hoch
Verifikation	

Tabelle 2: Functional requirements.

3.2 Nichtfunktionale Anforderungen

ID	Requirement	Priority
NFR-1	Lorem ipsum dolor sit amet, consectetur.	Must
NFR-2	Lorem ipsum dolor sit amet, consectetur adipiscing.	Must
NFR-3	Lorem ipsum dolor sit amet.	Should
NFR-4	Lorem ipsum dolor sit amet, consectetur.	Should

Tabelle 3: Non-functional requirements.

4 Design

4.1 Infrastruktur

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si aliquod aeternum et infinitum impendere malum nobis opinemur. Quod idem licet transferre in voluptatem, ut.

4.2 Phishing-Landing-Page

Kunde muss definiert werden.

4.2.1 Kategorien von Operational Security Massnahmen

Das Bestreben, eine schwer-erkennbare Landing-Page zu erstellen, ist keine leichte Aufgabe. Das Internet ist voller Bots, Crawler und Security-Scanner, die neu freigeschaltete Domains so schnell wie möglich durchforsten. Damit die in dieser Arbeit gebaute Landing-Page möglichst lange aushält und nicht verbrannt wird - d.h. nicht von Sicherheitsdiensten erkannt wird -, muss die Operational Security (OPSEC) der Phishing-Simulation gescheit aufgebaut werden.

Um eine hohe OPSEC zu erreichen, müssen verschiedene Sicherheitsmassnahmen und Strategien evaluiert und ausgewertet werden, um den Erfolg einer Phishing-Simulation zu maximieren. Im Grunde genommen können OPSEC-Sicherheitsmassnahmen für Phishing in zwei Kategorien eingeordnet werden:

1. Bot-Abwehr
2. Analyseerschwerung

Zur **Bot-Abwehr** gehören Massnahmen, die das Leben von Bots erschweren sollten, indem sie erkannt werden und die tatsächliche Landing-Page nicht angezeigt wird. Bots, Crawler oder Sicherheitsscanner sollten nicht zur tatsächlichen Landing-Page gelangen, die Phishing-Opfer sehen, da damit die Wahrscheinlichkeit erhöhen würde, dass sie eine Webseite als verdächtig oder Phishing markieren.

Zur **Analyseerschwerung** gehören Massnahmen, die die Analyse einer Landing-Page erschweren sollte, sei es ein Security-Researcher oder ein automatisierter Scanner, der die Landing-Page

analysiert. Hierbei sollten traditionelle signatur-basierte Security-Scanner umgangen werden um die operation der Phishing-Simulation zu gewährleisten.

In den nächsten zwei Kapiteln werden die zwei Kategorien mit einer ausführlichen Liste von möglichen Massnahmen ausgestattet. Das sollte dem Leser einen Überblick darüber verschaffen, welche Arten von Massnahmen zur jeweiligen Kategorie gehören. Die Listen sind nicht abschliessend, trotzdem werden die Massnahmen für die finale Phishing-Landing-Page von dieser Liste gewählt und begründet, weshalb diese gewählt wurde.

Die Listen basieren auf dem Kurs von mr.d0x et al. [5] und enthält für diese Arbeit relevante Strategien, von denen für das Endprodukt eine Kombination ausgewählt wird.

4.3 Bot-Abwehr Strategien

Komplexität: Niedrig, Mittel, Hoch

Name	Beschreibung
Geoblocking	Basierend auf der IP-Adresse kann der Standort des Clients identifiziert werden. Falls während einer Phishing-Simulation in der Schweiz ein Client aus dem Demokratischen Republik Kongo versucht die Landing-Page zu besichtigen, kann er geblockt werden; höchstwahrscheinlich ist er ein Bot.
TLD-Wahl	Es ist empfohlen, eine weltweit anerkannte TLD wie `.com`, `.org`, oder `.net` zu wählen, damit eine Landing-Page nicht ungewollt geblockt wird.
Domain-Wahl	Die Firma des Phishing-Simulation-Kunden sollte nicht im Second-Level-Domain registriert werden. Es ist empfohlen, die Firma im Subdomain zu verwenden, da viele Drittanbieter die Firma des Kunden im Subdomain für den Kunden hosten. Beispiel: Der Drittanbieter Safehosting AG hostet für BigMug AG unter dem Domain `bigmug.safehosting.com`.
Domain Add-ons	Die Dauer des registrierten Domains sollte nicht länger als ein Jahr sein, da die Domains meistens viel schneller verbrannt werden. Das Privacy-Add-on muss unbedingt mit dem Domain gekauft werden; der Kauf verhindert, dass die Domain-Registrar für die Öffentlichkeit zugänglich wird.

Name	Beschreibung
Reputation des Domains	Es soll sichergestellt werden, dass der ausgewählte, aber noch nicht gekaufte Domain, eine gute Reputation hat. Dazu können Tools wie Whois-History, VirustTotal, URLScan.io und die WaybackMachine verwendet werden.
Wildcard-Zertifikat	Wildcard-Zertifikate erhöhen die OPSEC, da sie für automatisierte Scanner das Scannen von Subdomains erschweren. In den *Certificate-Transparancy*-Logs (CT-Logs) wird ein Wildcard-Zertifikat als `*.domain.com` abgespeichert. Das bedeutet: Automatisierte Scanner können über unsere Subdomains von CT-Logs nicht erfahren. Für die Entdeckung eines Subdomains müsste ein Scanner aktiv Subdomains probieren und hoffen, dass es einen Treffer gibt [5, Modul 13].
Server-Sicherheit	Damit Bots eine Phishing-Webseite nicht als bösartig einstufen, müssen wir sicherstellen, dass HTTP-Zugriffe und direkte IP-Zugriffe verboten sind; Server-Informationen über HTTP-Header nicht freigegeben werden; und dass der *SSH-Verbose-Banner* ausgestellt ist [5, Modul 23].
Reverse-Proxy in der Allowlist	Damit der Phishing-Server von extern nicht gescannt wird, darf nur die IP-Adresse des Reverse-Proxys über HTTPS mit dem Server kommunizieren. Ein direkter Zugriff auf die Inhalte des Phishing-Servers soll nicht möglich sein [5, Modul 30].
Referrer-Policy	Falls die Phishing-Landing-Page nach erfolgreicher credential capturing den Client zur legitimen Login-Webseite weiterleitet, muss sichergestellt werden, dass beim Referrer-Policy „no-referrer“ steht. Umsonsten könnte es der Target-Firma auffallen, dass suspiciously viel traffic vom dem Phishing-Domain stammt [5, Modul 34].
Headless-Browsers	Viele automatisierte Scanner verwenden einen *Headless-Browser*, um Webseiten zu scannen. Anhand des `navigator.webdriver`-JavaScript-Objekts kann im Code herausgefunden werden, ob der Client einen *Headless-Browser* verwendet oder nicht. Im positiven Fall, kann der Client geblockt oder zur legitimen Webseite weitergeleitet werden [5, Modul 38].

Name	Beschreibung

Tabelle 4: Liste von Bot-Abwehr Massnahmen.

4.4 Analyseerschwerung

Name	Beschreibung	Komplexität
Meta Tags für SEO	Lorem ipsum dolor sit amet.	Should

Tabelle 5: Liste von Analyseerschwerung Massnahmen.

5 Implementation

5.1 Übersicht

Statistische Analysis

Dynamische Analysis

Live Analysis

5.2 Beispiel

```python
def greet(name: str) -> str:
    return f"Hello, {name}!"


print(greet("World"))
```

Listing 1: Example code.

6 Validierung

6.1 Guidelines

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si.

6.2 Experimente

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si.

6.3 Testing

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si aliquod aeternum et infinitum impendere.

7 Schlussfolgerung & Ausblick

7.1 Schlussfolgerung

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si aliquod aeternum et infinitum impendere malum nobis opinemur. Quod idem.

7.2 Ausblick

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si.

A Projektmanagement

A.1 Langfristiger Zeitplan

Für die Studienarbeit gilt die **~240 Stunden** Arbeitszeit einzuplanen.

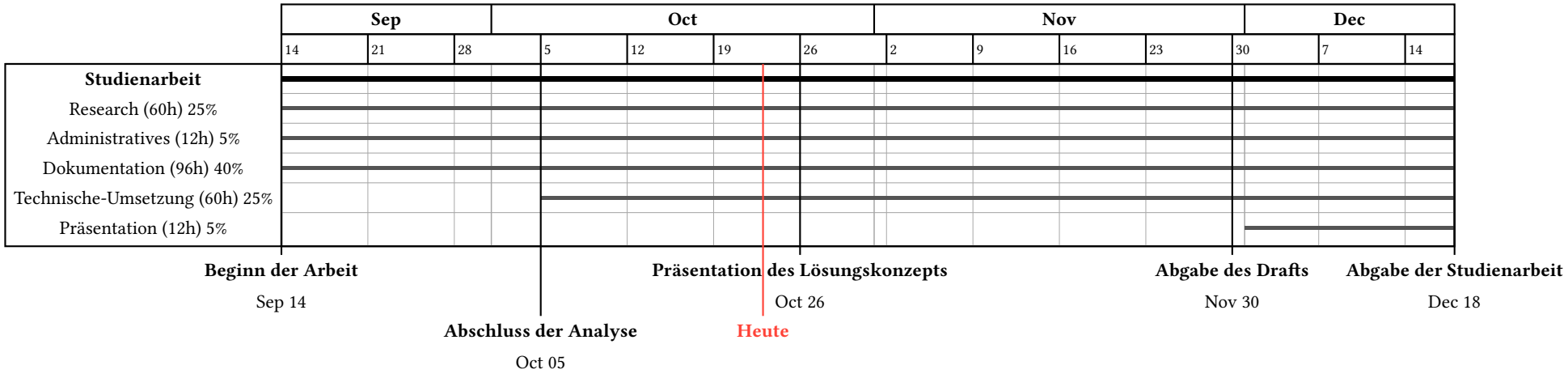


Abbildung 2: Langfristiger Zeitplan

A.2 Vorgehen im Projekt

(Prozess, Workflows, Meilensteine)

A.3 Qualitätssicherung

(Test-Philosophie, Definition of Done, CI/CD-Pipelines, Reviews)

A.4 Risikomanagement

A.4.1 Pre-Mitigation Risiken

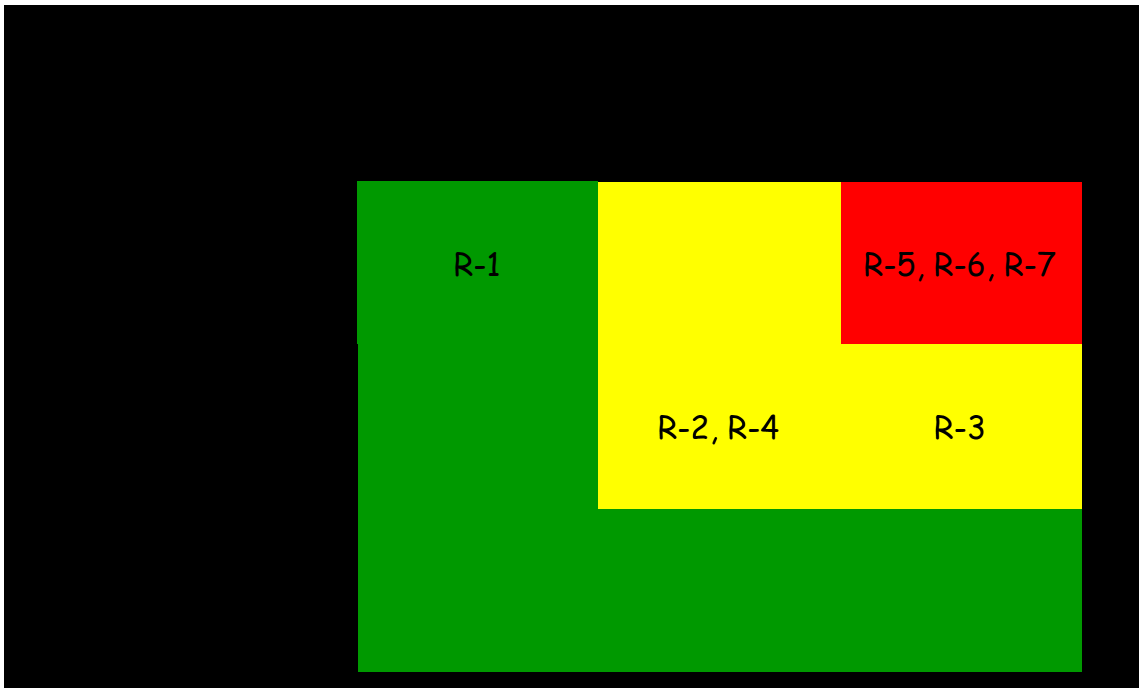


Abbildung 3: Risikomatrix vor Risikomitigation

Risiko-ID	Risiko-Beschreibung	Kategorie
R-1	Die Dokumentation entspricht den OST-Guidelines nicht.	🟢
R-2	Die Studienarbeit kann innerhalb des Zeitlimits nicht erfolgreich abgeschlossen werden.	🟡
R-3	Die Dokumentation wird während des Projekts nicht adäquat gepflegt.	🟡
R-4	Scope Creeping (Umfangsausweitung) der Studienarbeit.	🟡
R-5	Es ist nicht möglich, eine Phishing-Landing-Page zu bauen, die Sicherheitsscanner täuschen kann.	🔴
R-6	Die Studienarbeit bietet keinen Mehrwert für avantguard.	🔴
R-7	Beim Research werden keine erfolgreiche Anti-Analysis-Techniken gegen Sicherheitsscanner gefunden.	🔴

Tabelle 6: Risikotabelle

A.4.2 Post-Mitigation Risiken

Risiko-ID	Mitigations-Beschreibung	Neue Kategorie
R-1	Am Anfang des Projekts soll eine Liste mit Anforderungen an die Dokumentation erstellt werden, die vor der Abgabe der Arbeit überprüft werden müssen. Die Liste soll durchgangen werden und wie eine Checkliste abgehakt werden.	
R-2	Während der Arbeit soll nicht nur qualitativ, aber auch quantitativ 17 Stunden Arbeit in der Woche angestrebt werden. Dies sollte sicherstellen, dass aus dem Zeitbudget das bestmögliche Resultat rausgeholt wird.	
R-3	Von Anfang an sollte jede Woche mindestens drei Stunden lang dokumentiert werden. Diese Massnahme stellt sicher, dass die Dokumentation während des Projekts aktuell gehalten wird.	
R-4	Am Anfang sollten mit Hilfe von Meetings detaillierte nicht-funktionale sowie funktionale Anforderungen erstellt werden. Diese müssen den Vorstellungen von avantguard entsprechen und ein machbares und realistisches Projekt sicherstellen.	
R-5	Durch viel in Phishing-Research investierte Zeit sollte das Risiko minimiert werden, indem Strategien und Techniken gelernt werden.	
R-6	Gegen Ende der Arbeit wird eine Präsentation im Büro von avantguard gehalten, um sicherzustellen, dass avantguard einen Überblick über die Arbeit verschaffen kann, ein Wissenstransfer stattfindet und avantguard eine Gelegenheit hat, Fragen bezüglich des Projekts zu stellen. Diese Präsentation soll den Mehrwert des Projekts für avantguard maximalisieren.	
R-7	Ein Kurs von MaldevAcademy wird gekauft, um die benötigte Anti-Analysis-Techniken anzueignen.	

Tabelle 7: Mitigationstabelle

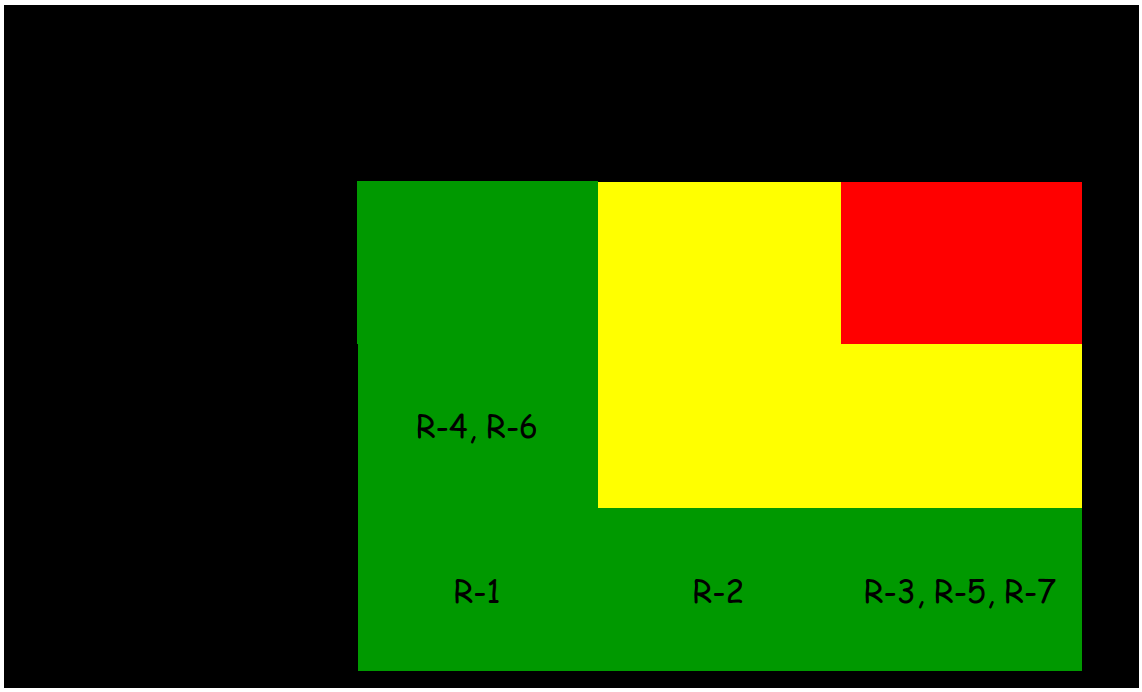


Abbildung 4: Risikomatrix nach Risikomitigation

A.5 Zeiterfassung

A.6 Meetings

A.6.1 Überblick

Nr.	Datum	Zeit	Name	Teilnehmende
1.	29.09.2026	11:00-11:30	Kick-off Meeting	Dr. Arno Wagner, András Tarlós
2.	29.09.2026	18:00-19:00	Requirements-Eng.	Sandro Ackerman, András Tarlós
3.				

A.6.2 Protokoll

A.6.2.1 Kick-off Meeting

Teilnehmende	Dr. Arno Wagner, András Tarlós
Datum	29.09.2026
Uhrzeit	18:00 - 19:00
Ablauf	1. Wagner stellt seine Erwartungen an die Studienarbeit (SA) vor: • Das Problem wird definiert. • Der Stand der Technik wird beschrieben. • Die Motivation der Arbeit wird definiert. • Die Ziele der Arbeit sind definiert. • Es wird beschrieben, wie getestet wird. • Beim Abschluss wird beschrieben, was die Arbeit gebracht hat. 2. Tarlós stellt seine Fragen an Wagner. 3. Die erste Version der Dokumentation wird mit Wagner überprüft und unnötige Inhalte werden gelöscht.
Erkenntnisse	• Während der SA können potenzielle Themen für die Bachelorarbeit identifiziert werden. • Eine Präsentation bei der SA ist nicht obligatorisch. • Falls beim Praxispartner präsentiert wird, sollte auch Wagner eingeladen werden, falls möglich. • Meetings sind flexibel am Montag. • Meetings sind alle zwei Wochen vorgesehen. • Das Zertifikat vom MaldevAcademy-Kurs sowie das Inhaltsverzeichnis des Kurses dem Anhang hinzufügen.

A.6.2.2 Requirements-Engineering

Teilnehmende	Sandro Ackerman, András Tarlós
Datum	29.09.2026
Uhrzeit	11:00 - 11:30
Ablauf	1. Ackerman stellt vor, wie eine typische Phishing-Simulation bei der avantguard cyber security AG aussieht. 2. Tarlós stellt Fragen zur Phishing-Infrastruktur. 3. Ackerman spezifiziert das Problem bei der Phishing-Simulation. 4. Es wurde eine für diese Studienarbeit relevante Experimentidee entwickelt.
Erkenntnisse	• Für die Phishing-Infrastruktur werden die kleinsten Ubuntu-VMs auf Azure gemietet. Auf einer VM wird der GoPhish-Server gehostet, während eine andere aktuell als Reverse-Proxy verwendet wird. • Das Admin-Portal des GoPhish-Servers ist nur intern von dem IP-Bereich von avantguard erreichbar; alle anderen IPs werden geblockt. • Avantguard hat lange Let's-Encrypt-Zertifikate verwendet, neuerdings aber von Azure ausgestellte Zertifikate (https://learn.microsoft.com/en-us/azure/virtual-machines/create-fqdn). Das hat den Vorteil, dass Microsoft Ltd. der Aussteller des Zertifikats ist. • Bei Phishing-Simulationen werden fast ausschliesslich Microsoft-Login-Kopien verwendet. • Bei verschiedenen Kunden ist eine Änderung des Microsoft-Logos und des Hintergrunds vorgesehen, die bei der Phishing-Simulation repliziert werden muss. Firmen können das Logo und das Hintergrundbild von ihrem Microsoft-Login individualisieren. • Die aktuell verwendete Microsoft-Login-Kopie von avantguard basiert auf einem Template und wurde von Hand geschrieben. • Avantguard hat das Problem, dass ihres Phishing-Landing-Page nach dem Start der Phishing-Simulation meistens innerhalb von zwei Tagen als Phishing markiert wird. Falls die E-Mails nicht ausgeschickt werden, wird das Landing-Page nicht als Phishing markiert. Daraus

haben Ackerman und Tarlós abgeleitet, dass höchstwahrscheinlich die E-Mail-Provider die Links zum Scannen weiterleiten.

- Um das in der letzten Bulletpoint erwähnte Problem zu bestätigen, wurde ein Experiment konzipiert, bei dem der Website-Verkehr einer Phishing-Webseite vor und nach dem Versenden von E-Mails beobachtet werden sollte.
- Ein potenzielles IOC von GoPhish könnte der statische URL-Parameter „id“ sein.
- Die Ergebnisse der Studienarbeit sollten in Form von einer Präsentation bei avantguard vorgestellt werden. Wagner darf ebenfalls eingeladen werden. Die Präsentation sollte der Firma einen Mehrwert bieten und die Kernaussagen der Arbeit ohne schulische Formalitäten vermitteln.

B Persönliche Reflexion

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magnam aliquam quaerat voluptatem. Ut enim aeque doleamus animo, cum corpore dolemus, fieri tamen permagna accessio potest, si aliquod aeternum et infinitum impendere.

C Diagramme

Abbildung 1 Ablauf einer Phishing-Simulation 2
Abbildung 2 Langfristiger Zeitplan 12
Abbildung 3 Risikomatrix vor Risikomitigation 14
Abbildung 4 Risikomatrix nach Risikomitigation 16
Abbildung 5 Abschlusszertifikat Maldev Academy 30

D Tabellen

Tabelle 1 Liste aller Abkürzungen 3
Tabelle 2 Functional requirements. 4
Tabelle 3 Non-functional requirements. 4
Tabelle 4 Liste von Bot-Abwehr Massnahmen. 6
Tabelle 5 Liste von Analyseerschwerung Massnahmen. 8
Tabelle 6 Risikotabelle 14
Tabelle 7 Mitigationstabelle 15
Tabelle 8 Maldev Academy Modul-Liste 26

E Listen

Listing 1 Example code. 9

F Literaturverzeichnis

[1] G. Ho *u. a.*, „Understanding the Efficacy of Phishing Training in Practice“, *IEEE Symposium on Security and Privacy (SP)*, 2025.

[2] K. Alluqmani, A. E. Karrar, M. Alhaidari, und R. Alharbi, „Assessing the Efficacy of Security Awareness Training in Mitigating Phishing Attacks: A Review“, *International Journal of Advanced Trends in Computer Science and Engineering*, Bd. 14, Nr. 3, S. 177–184, 2025.

[3] W. Li, S. Manickam, Y. Chong, W. Leng, und P. Nanda, „A State-of-the-Art Review on Phishing Website Detection Techniques“, *IEEE Access*, Bd. 12, S. 187976–188012, 2024, doi: 10.1109/ACCESS.2024.3514972.

[4] L. Tang und Q. H. Mahmoud, „A survey of machine learning-based solutions for phishing website detection“, *Machine Learning and Knowledge Extraction*, Bd. 3, Nr. 3, S. 672–694, 2021.

[5] mr.d0x *u. a.*, „Offensive Phishing Operations course“. Zugegriffen: 23. Oktober 2026. [Online]. Verfügbar unter: https://maldevacademy.com/phishing-course

G Maldev Academy

Modul	Name
1	Introduction
2	Introduction To Phishing
3	Development Environment
4	Basic Phishing Requirements
5	Analyzing Phishing Requirements
6	Phishing Detection Methods
7	Practical Phishing Detection Examples
8	Selecting Hosting Providers
9	Deploying Phishing Infrastructure
10	Web Server Setup: Apache & PHP
11	Domain and DNS Configuration
12	SSL Configuration: Let's Encrypt
13	Wildcard Certificate Via Let's Encrypt
14	SSL Configuration: Comodo SSL
15	Database Setup: MySQL
16	Web Server Setup: Nginx & Flask
17	Introduction To Flask
18	Cloning Websites Via Browser Extension
19	Cloning Detection Mechanisms
20	Designing Custom Phishing Pages
21	Integrating Backend Functionality
22	Performing Input Validation
23	Analyzing Server Security
24	Securing Server: Restrict HTTP Access
25	Securing Server: Blocking Direct IP Access
26	Securing Server: Removing Verbose Information

Modul	Name
27	Secure SSH Configuration
28	Securing Server Via Cloudflare
29	Introduction To Apache Mod_Rewrite
30	Protecting Phishing Server Via Mod_Rewrite
31	Introduction To Nginx's Capabilities
32	Nginx Demo: Reverse Proxying NordVPN.com
33	Protecting Phishing Server Via Nginx
34	Hiding Domain Via Referrer-Policy
35	Introduction To Caddy
36	Protecting Phishing Server Via Caddy
37	Anti-Analysis Via Cookie Check
38	Detecting Headless Browsers Via WebDriver Property
39	Anti-Bot Via User Agent Filtering
40	Anti-Bot Via User-Agent Spoofing Detection
41	Anti-Analysis Via IP Restrictions
42	Anti-Analysis Via Dynamic HTML Generation
43	Anti-Analysis Via Base64 Obfuscation
44	Anti-Analysis Via XOR Obfuscation
45	Anti-Analysis Via AES Encryption
46	Anti-Analysis Via Dynamic Encryption
47	Anti-Analysis: Dynamic Obfuscation via Obfuscator.io
48	Anti-Analysis Via Fetching Remote Content
49	Anti-Analysis Via User Interaction
50	Anti-Analysis Via Honeypots
51	Anti-Analysis Via Website Keying
52	Anti-Bot Via CAPTCHA
53	Anti-Bot Via Improper Window Size
54	Anti-Analysis: Approve Access Via Email
55	Anti-Analysis: Approve Access Via Push Notifications
56	Anti-Analysis: Approve Access Via Discord

Modul	Name
57	Incognito Mode Detection
58	Ad Blocker Detection
59	Opsec Failure: Directory Listing
60	WHOIS Reputation Analysis
61	Historical DNS Records
62	Improving Domain Reputation: Domain Aging
63	Improving Domain Reputation: Domain Categorization
64	Improving Domain Reputation: Web Traffic
65	Serverless Phishing: Cloudflare Worker
66	JARM Fingerprinting
67	JA3/JA3S Fingerprinting
68	JA4/JA4S Fingerprinting
69	JA4 Analysis: Calculating JA4 Fingerprints
70	JA4 Analysis: Blacklisting JA4 Fingerprints
71	JA4 Analysis: Blacklisting Partial JA4 Fingerprints
72	JA4 Analysis: Whitelisting Partial JA4 Fingerprints
73	Building a Client Logging Library
74	Collecting & Identifying Bot Telemetry
75	Building An Anti-Bot Library
76	Evading Google Safe Browsing
77	Manual Timed-Based One-Time Password (TOTP) Harvesting
78	Adversary-In-The-Middle (AITM) Via Evilginx
79	Customizing Evilginx: Opsec Configuration
80	HTML Smuggling
81	Automate Phishing Infrastructure: Terraform
82	Automate Phishing Infrastructure: Ansible
83	Collecting & Analyzing JA4 Bot Telemetry
84	Anti-Bot Via Advanced JA4 Analysis
85	HTML Smuggling Strategies
86	Analyzing & Evading SmuggleShield

Modul	Name
87	Integrating Anti-Bot Measures With HTML Smuggling
88	SVG Smuggling
89	WebAssembly Smuggling
90	Introduction To ClickFix
91	ClickFix: Run Dialog Alternatives
92	Anti-Analysis Via Reverse DNS Query
93	Anti-Analysis Via Invisible Encoding
94	MFA Bypass: Building An Invisible Proxy
95	Invisible Proxy: Opsec Considerations
96	MOTW Bypass Via FileFix Variations
97	MFA Bypass: Building An Invisible Proxy Via Cloudflare Workers
98	Protecting Evilginx Server Via Caddy
99	Microsoft Device Code Phishing
100	GitHub Device Code Phishing
101	Illicit Consent Grant
102	GitLab Device Code Phishing
103	Client Analysis Via Cloudflare Workers
104	Evilginx Phishlet Development
105	Evilginx URL Rewriting
106	Dynamic Device Code Phishing
107	MFA Bypass: Azure AiTM Phishing
108	Google Phishing: BotGuard, Browser Automation, and Chrome Sync
109	Phishing Passkeys
110	ConsentFix Attack

Tabelle 8: Maldev Academy Modul-Liste



Abbildung 5: Abschlusszertifikat Maldev Academy